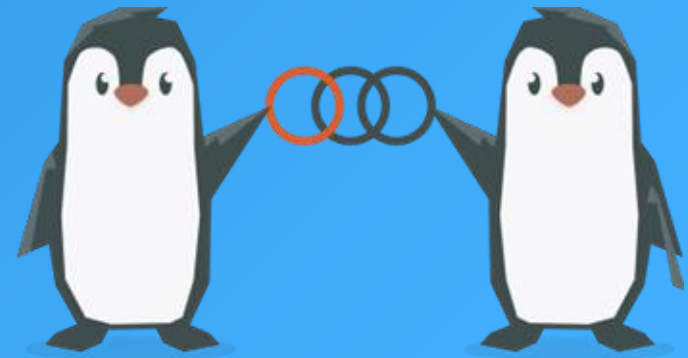


Open Source based Supply Chain Management at Scale

OpenChain Community Day Beijing 2026
2026-08-06



Whoami



Nikola Babadzhanov

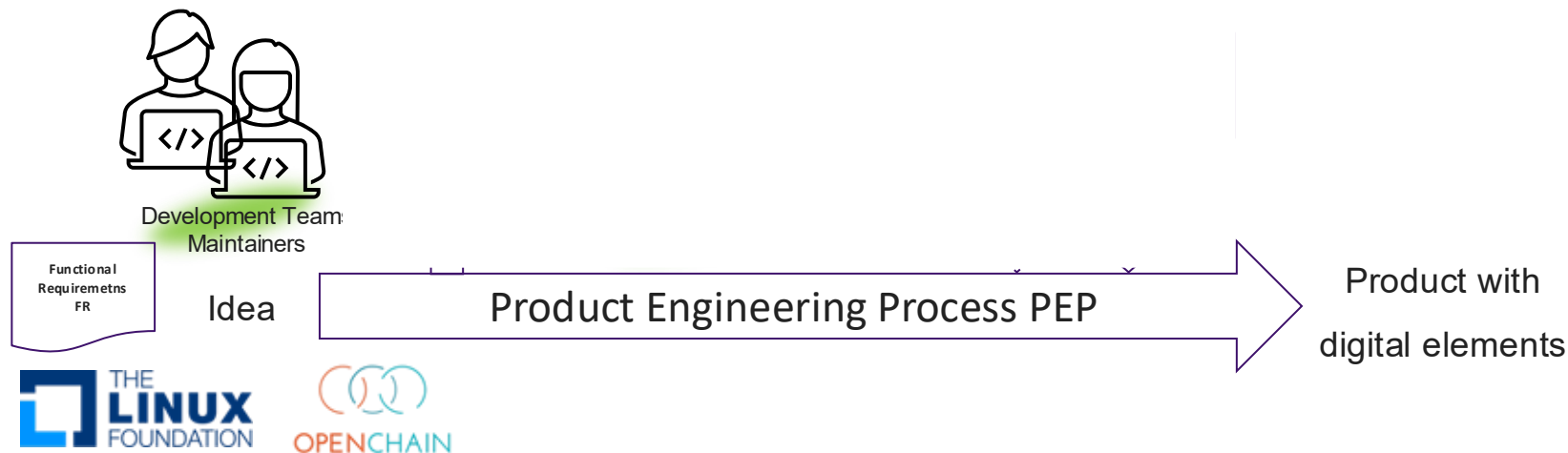
Software & Open Source Management Consultant @ Bosch OSPO

- *OpenChain Ambassador*
- *Member of OpenChain SBOM Study group, Automation WG and AI WG*
- *Chair of Solution Circle Secure and Compliant Containers*
- *Eclipse Apoapsis committer*

Big Picture

simplified

In the beginning everyone was happily developing ...



Big Picture

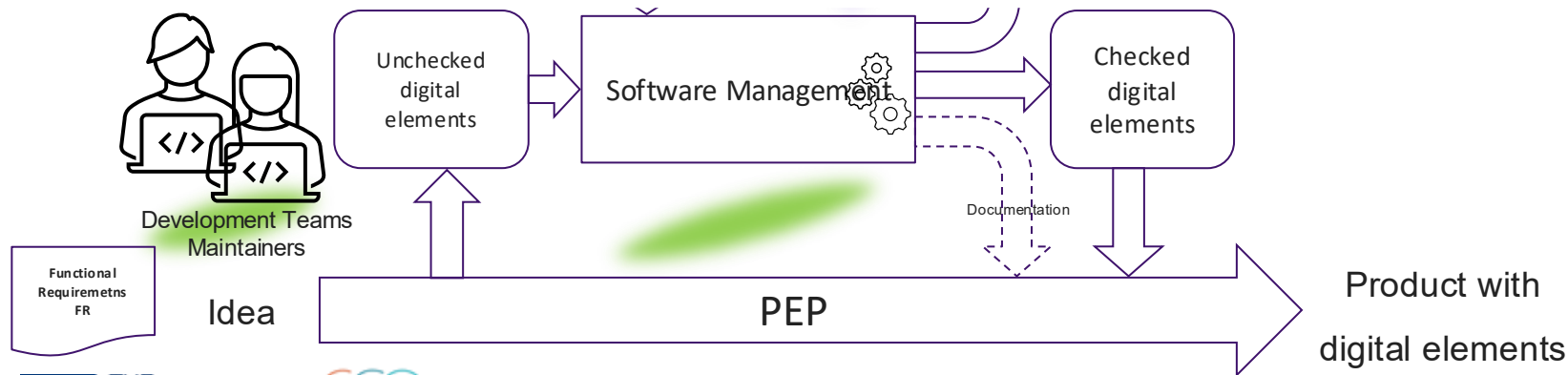
simplified

Non-Functional
Requirements
NFR



Then...

Checking NFRs?



Big Picture

simplified

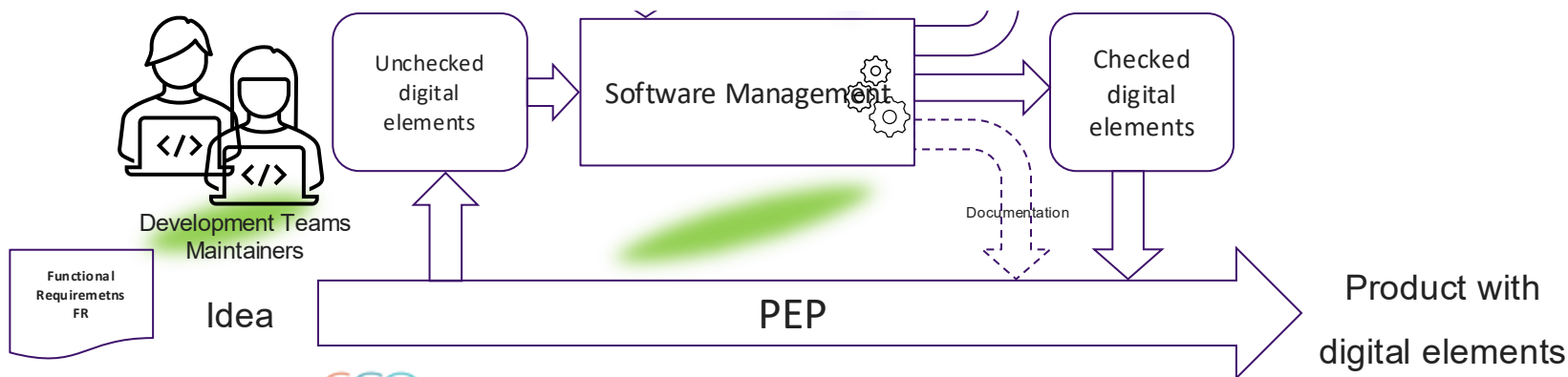
Non-Functional
Requirements
NFR



AI generated image

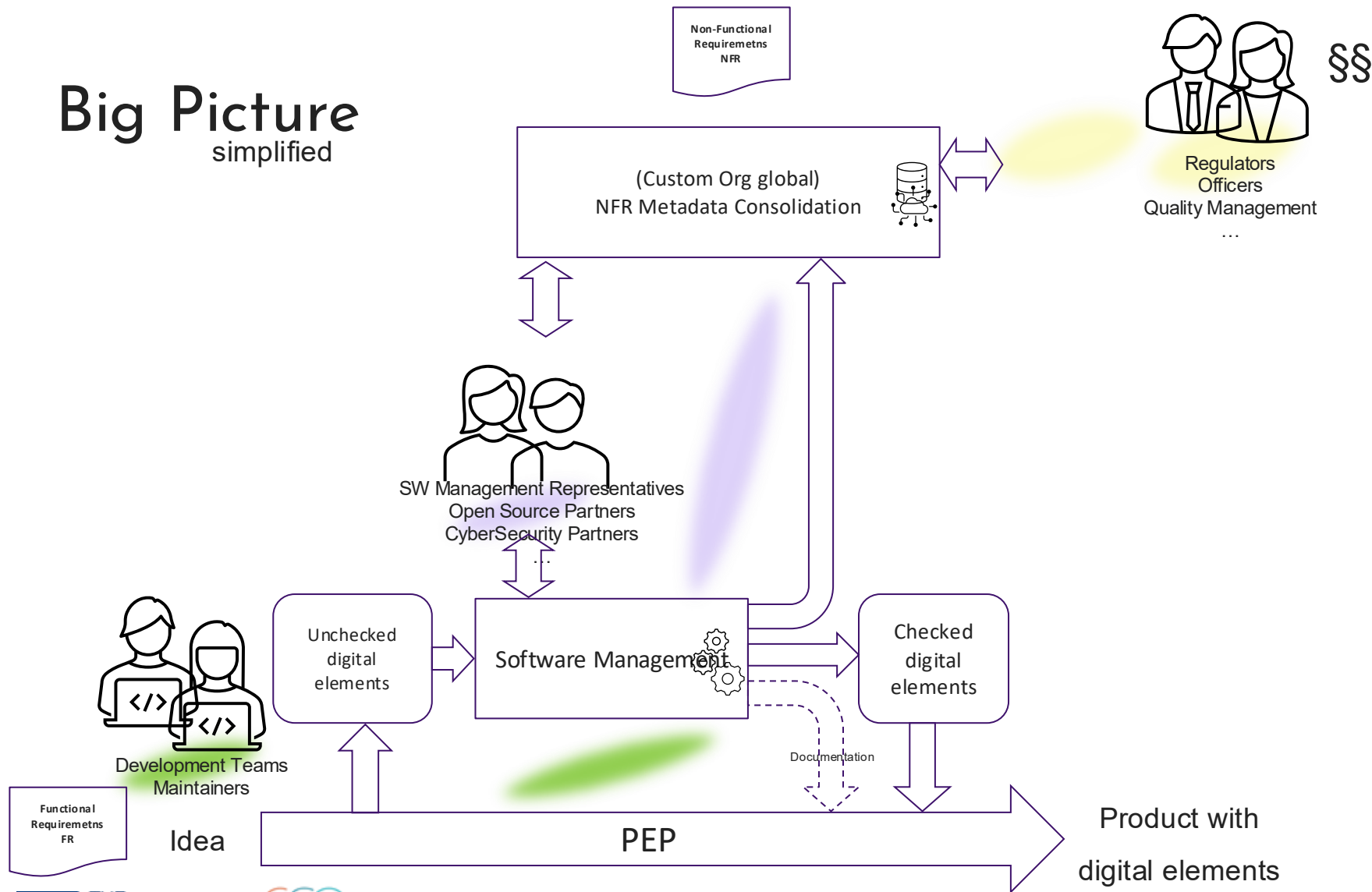
Need to bridge the gap!

Translate NFRs in a way that they can be understood and checked.

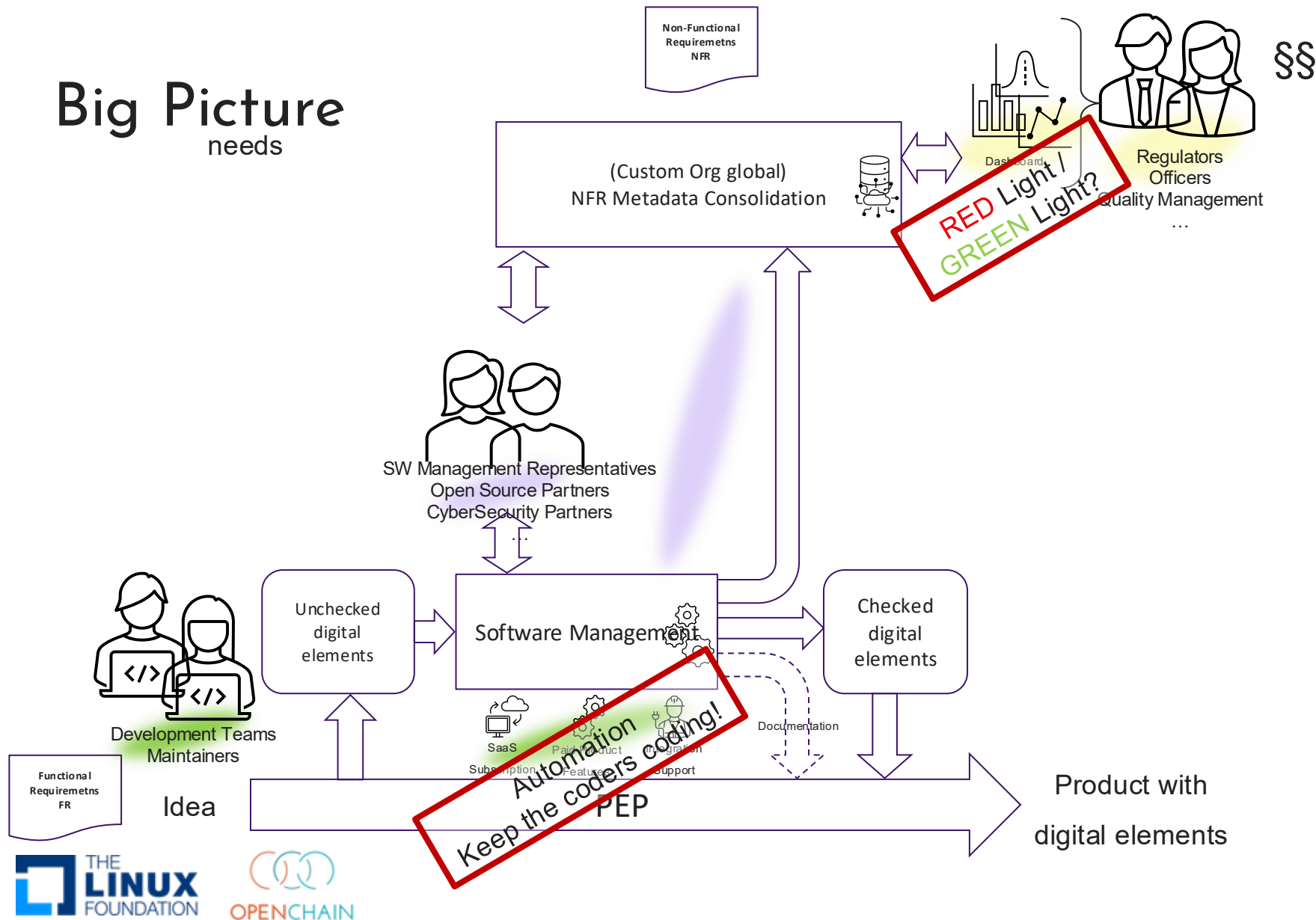


Big Picture

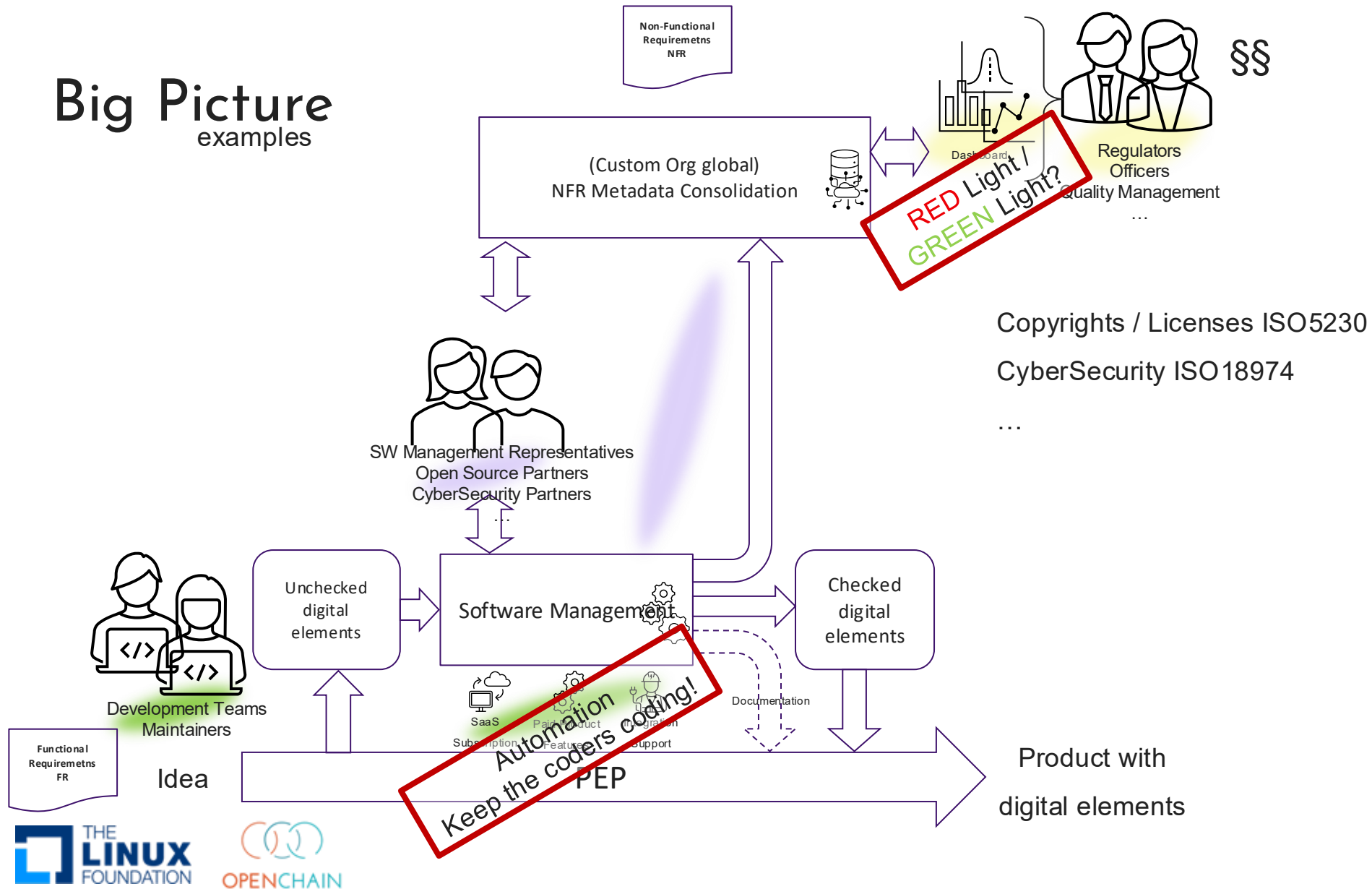
simplified



Big Picture needs

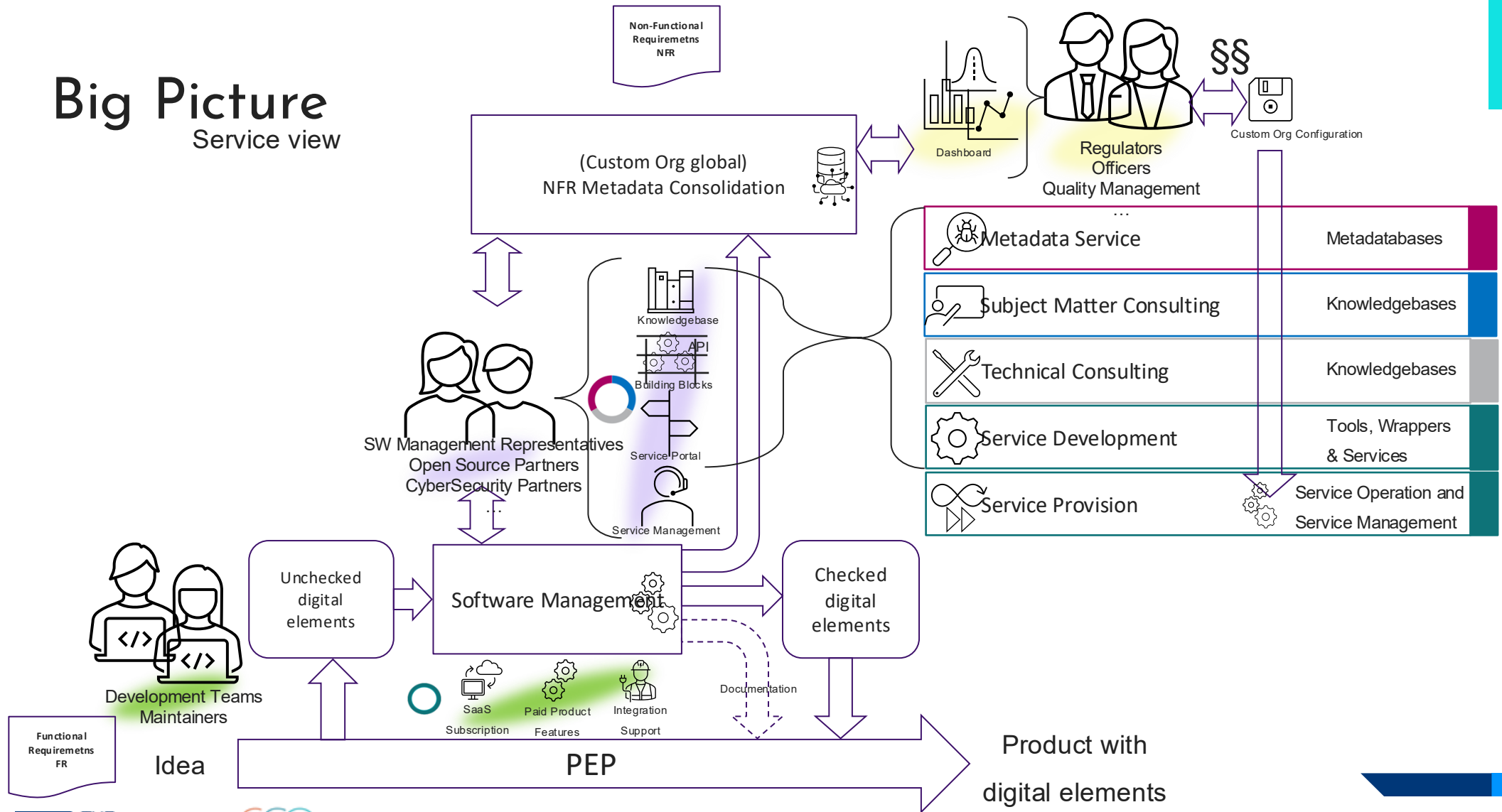


Big Picture examples



Big Picture

Service view

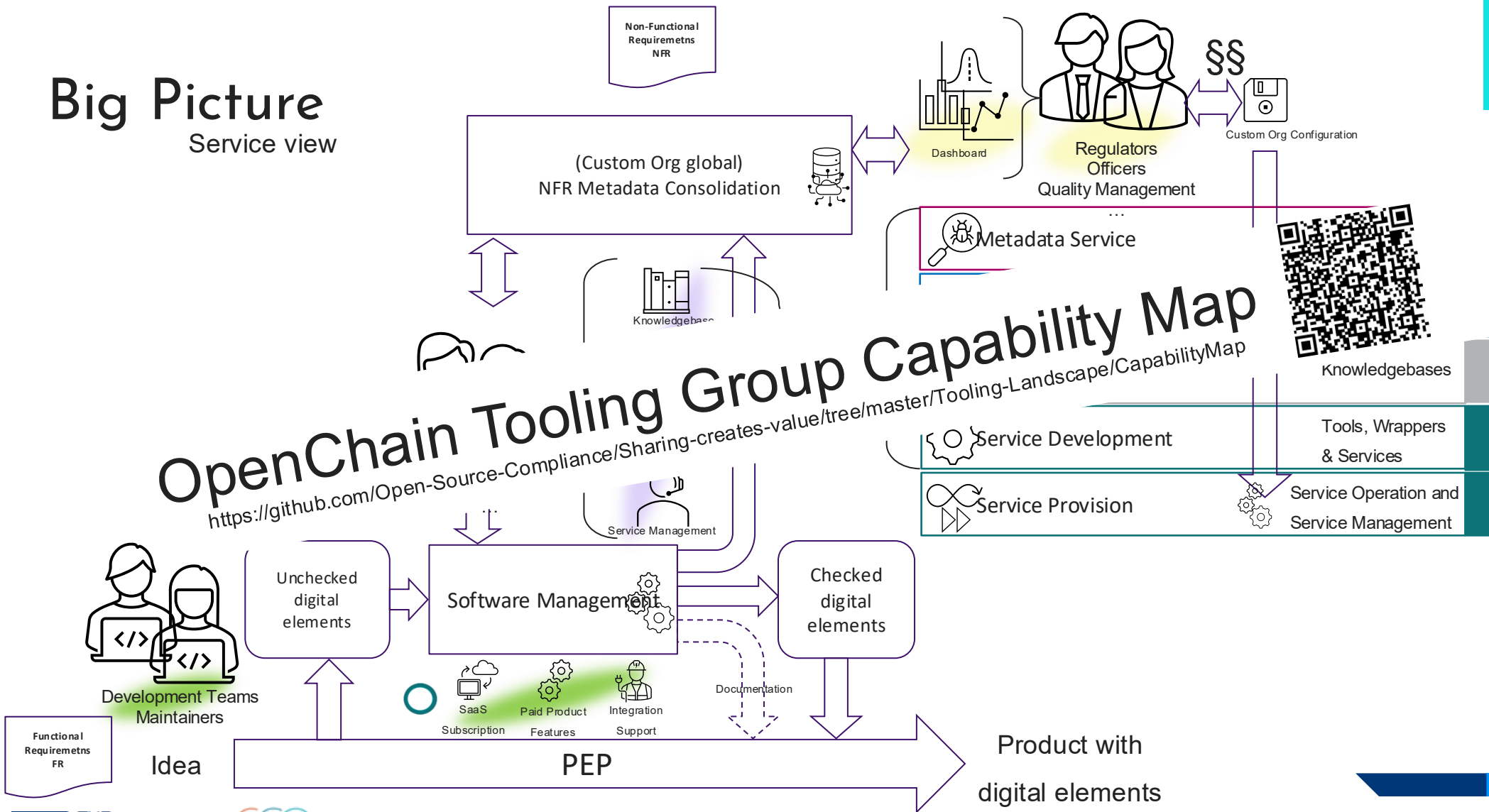


Big Picture

Service view

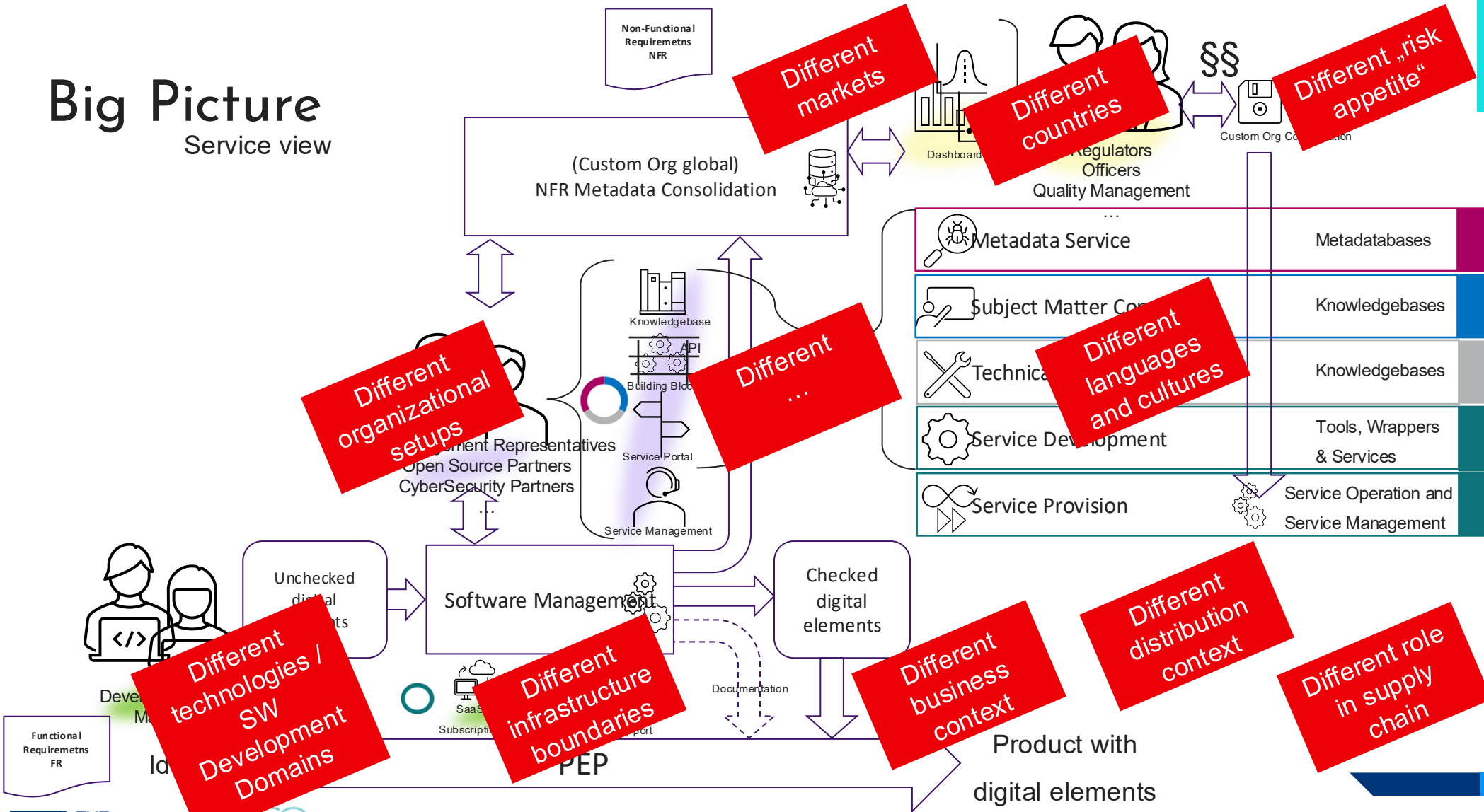
OpenChain Tooling Group Capability Map

<https://github.com/Open-Source-Compliance/Tooling-Landscape/CapabilityMap>



Big Picture

Service view





We are community of problems, and we
need your problems!

Goals and needs

- Find match: Map your needs and
 - ... find existing solutions
 - ... find birds of a feather



Fact sheets

- Share and reuse



Generic architecture
model

- Standardizing while keeping flexibility



Standardized
representation

Finding clothes online

1st limitation of search range

Women OR Men OR Kids

2nd limitation of search range

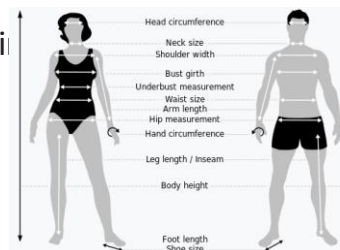
Clothing OR Shoes OR Sportswear OR ...

3rd limitation of search range

Jackets OR T-Shirts OR Pants OR ...

4th limitation of search range

Size ? Determine
parameters



„Fact sheet“

Size Chart

XS, S, M, L, XL

Source: https://commons.wikimedia.org/wiki/File:Body_measures_SVG.svg

Get overview of all clothes matching to your parameters

Software and Open Source Management



Software Supply Chain View

Problem Space

Generic Software Supply Chain Architecture

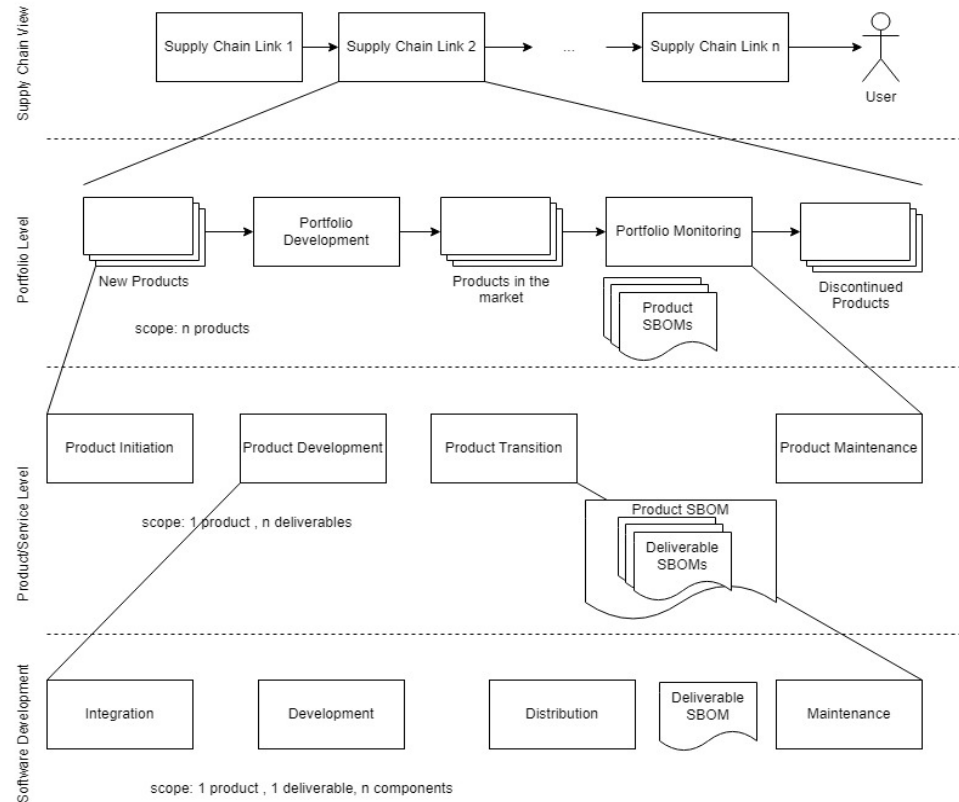
Software Supply Chain Blueprints

Software Management on Product/Service Level

Problem Space

Generic Architecture for Software Management on Product Level

Blueprints for Software Management on Product/Service Level



Software Management on Portfolio Level

Problem Space

Generic Architecture for Software Management on Portfolio Level

Blueprints for Software Management on Portfolio Level

Software Development Monitoring

Problem Space

Generic Architecture for Software Development Monitoring

Blueprints for Software Development Monitoring

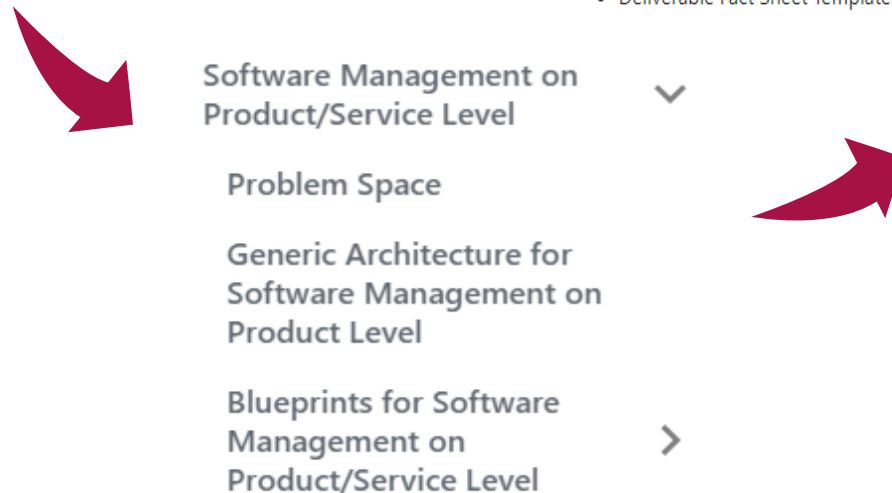


Blueprint use - scenario

As product owner or product responsible, I want to have a blueprint for software component lifecycle, so..

Blueprints for Software Management on Product/Service Level

- **Component Lifecycle Process**
- Deliverable Dashboards
- Deliverable Fact Sheet Templates





Blueprint use - scenario

As a [Security Manager] I want to have a **Product Dashboard** so that I can continuously monitor the security status.

Blueprints for Software Management on Portfolio Level

- Product Dashboards
 - Consolidation of Product Fact Sheet templates
 - OWASP Dependency Track
- Product Fact Sheet templates
- **ORT-Server**



Software Management on
Portfolio Level

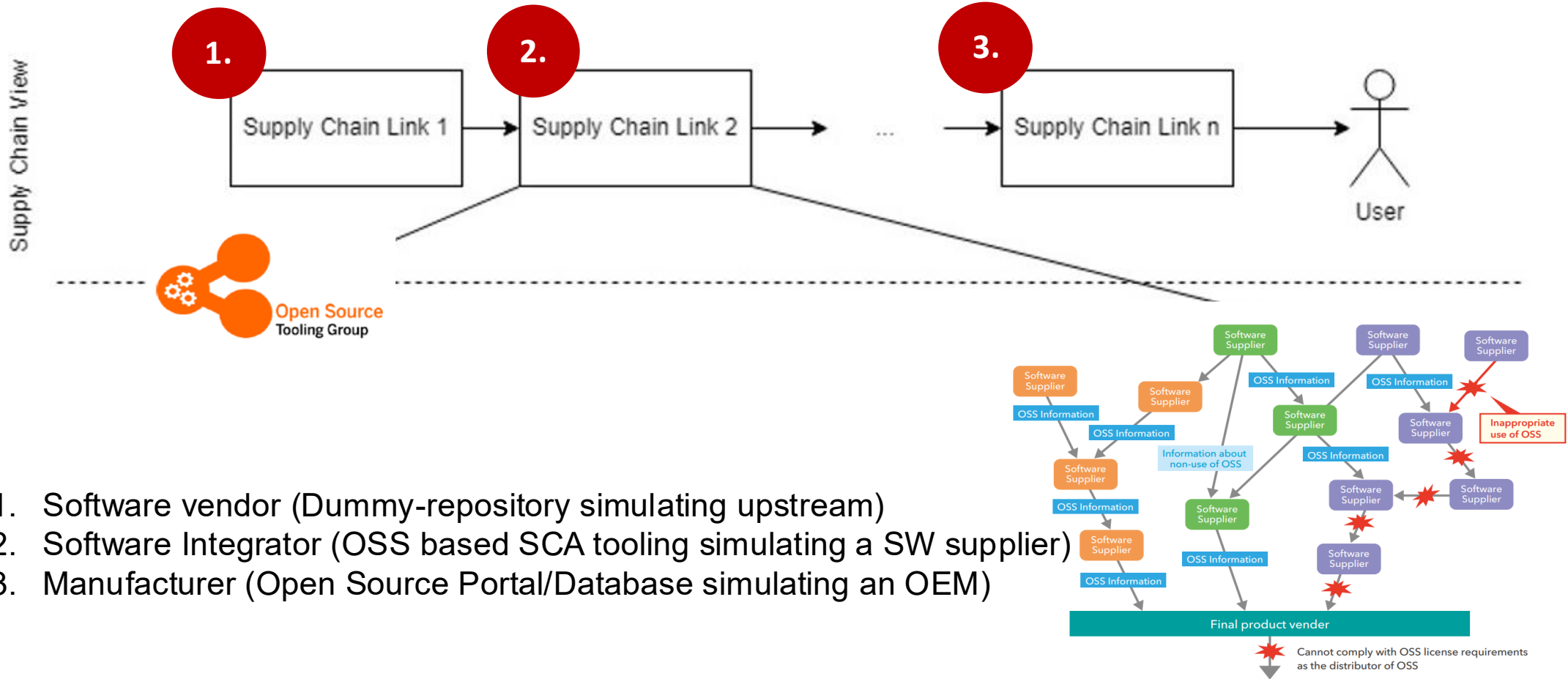


Problem Space

Generic Architecture for
Software Management on
Portfolio Level

Blueprints for Software
Management on Portfolio Level

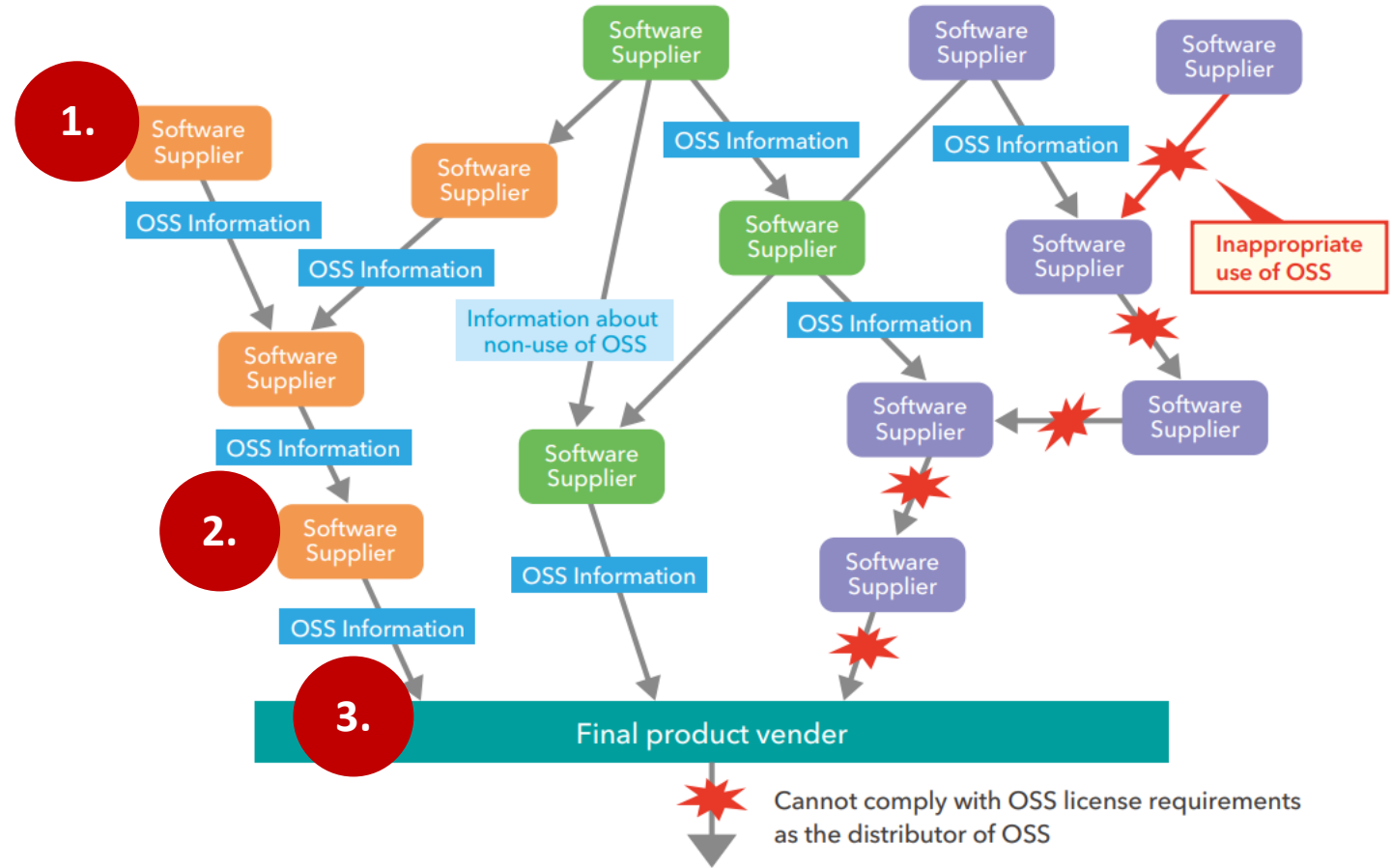
Establish a publicly available supply chain simulation



Supply Chain

Recap

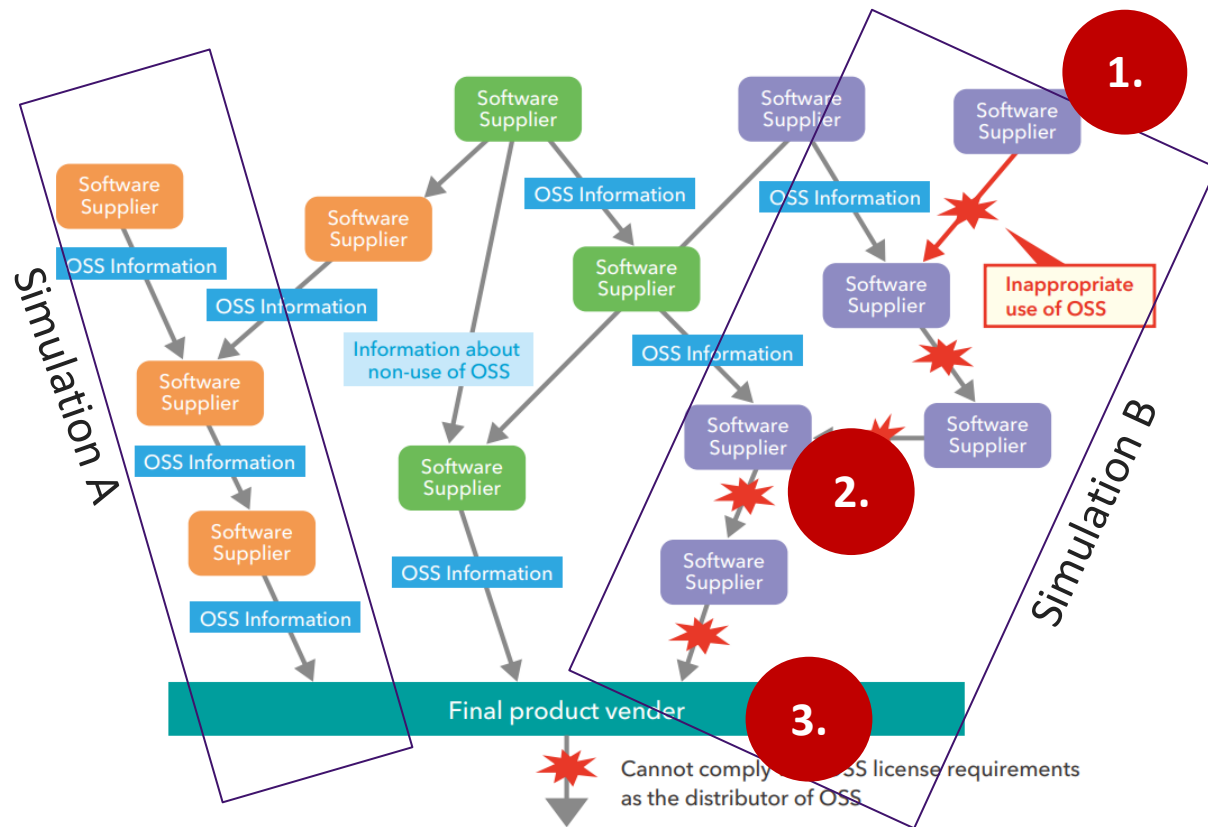
Different links in the „chain“
Different contexts
Different use cases
Different problem spaces



Source: <https://github.com/OpenChain-Project/Reference-Material/blob/master/Education-For-Suppliers/Supplier-Education-Leaflet/supply-chain-education-leaflet-version-1-2019/OpenChain-2.1-Edition/en/supplier-leaflet-en.pdf>

Idea

Establish a publicly available supply chain simulation

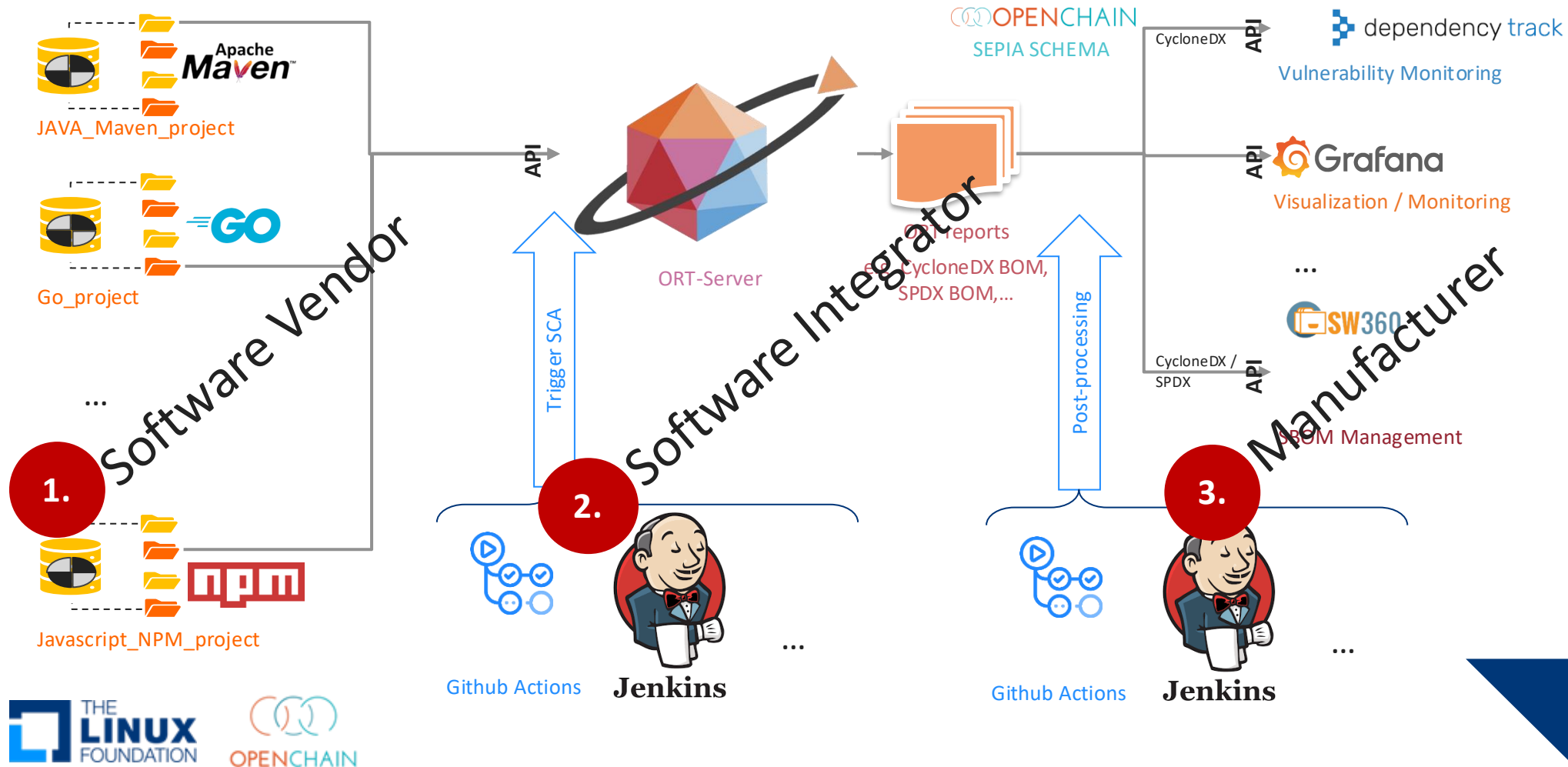


Benefits:

- Use for trainings
- Use for showcases
- Use for testing the tool chain / infrastructure
- Reference for interface discussions
- ...

Source: <https://github.com/OpenChain-Project/Reference-Material/blob/master/Education-For-Suppliers/Supplier-Education-Leaflet/supply-chain-education-leaflet-version-1-2019/OpenChain-2.1-Edition/en/supplier-leaflet-en.pdf>

Setup End-to-end (principle)



Standardized Blueprint Descriptions

Blueprint Documentation



- Intro
- PART A) Context Knowledge >
- PART B) - Software and Open Source Management >
- Software Supply Chain View >
- Problem Space
- Generic Software Supply Chain Architecture
- Software Supply Chain Blueprints >
- Public available supply chain simulation based on Open... >
- Public available supply chain simulation
- Software Management on Portfolio Level >
- Software Management on Product/Service Level >
- Software Development Monitoring >
- Get involved >

Home > PART B) - Software and Open Source Management > Software Supply Chain View > Software Supply Chain Blueprints >

Public available supply chain simulation based on Open Source

Basic Simulation Showcase Setup

The basic simulated supply chain is meant to be as simple as possible and consists of three parts:

1. Part that simulates a original Software vendor (e.g. an upstream Open Source Project) with a code repository.
2. Part that simulates a Software integrator (e.g. a Software supplier that re-uses Open Source components in a derivative work) that ships a combined work and provides an SBOM
3. Part that simulates a manufacturer that gets several SBOMs from various suppliers and needs to manage them

Part 1 - Software vendor

- A) The simulation uses the [Dummy Repositories from the OpenChain Tooling group](#)
- B) The dependency-tree can be shown in the [Github Dependency graph](#)
Hint: You can use a local [ORT-installation](#) as alternative to create the dependency graph.

for simplicity Github with its onboard equipment was used instead of insisting on complete open source setup - so it is publicly available but not Open Source => Improvement potential

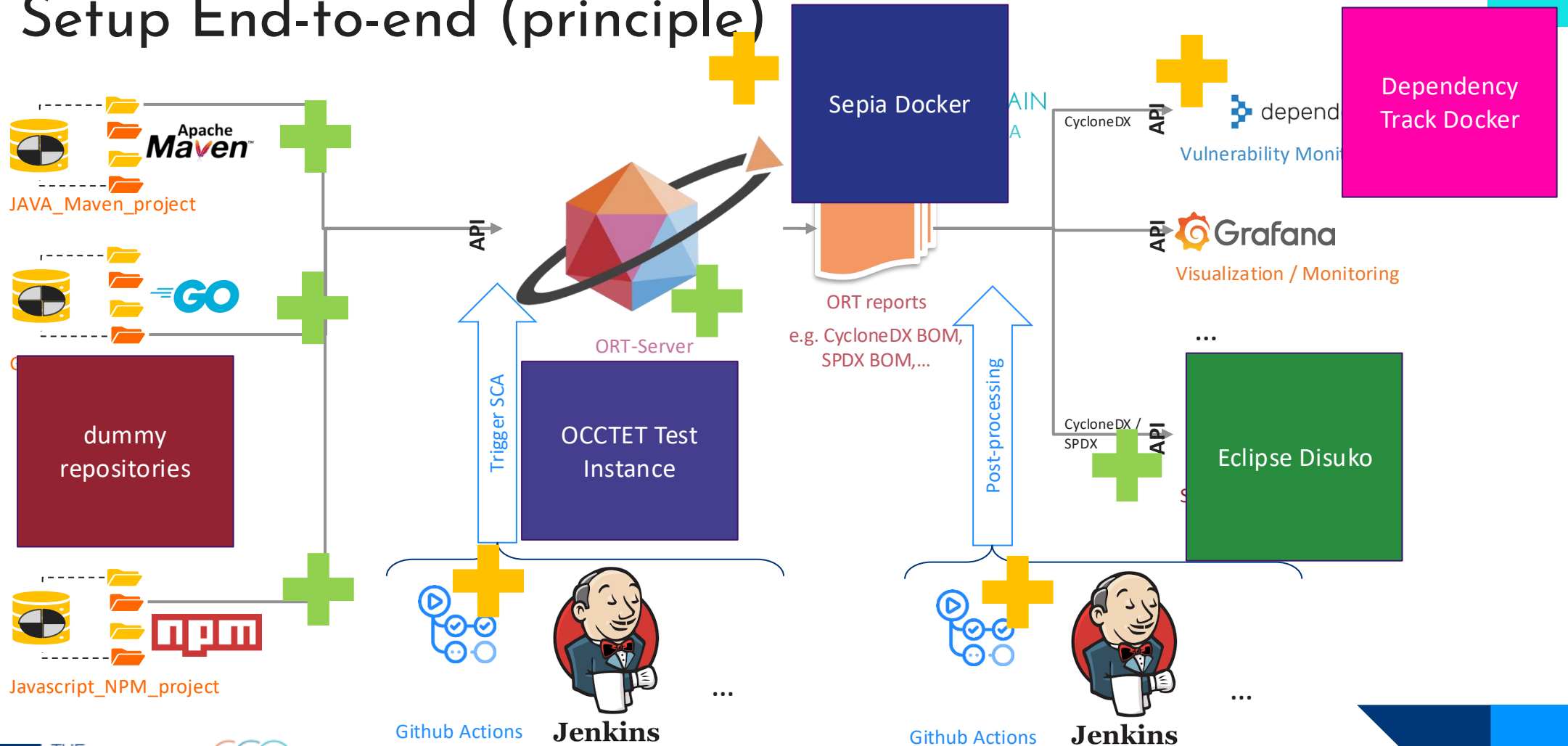
Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy
- B) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/network/dependencies



Supply Chain SBOM Reference Tooling

Setup End-to-end (principle)



The software vendor

The main actors

1.

- 3-4 dummies currently available
 - Issues for improvement: additional dummies + blueprint based on OSS IDE instead of VS Code
 - Communication in our meetings and via issues: <https://github.com/Open-Source-Compliance/Sharing-creates-value/issues>



Part 1 - Software vendor

- A) The simulation uses the **Dummy Repositories** from the OpenChain Tooling group
- B) The dependency-tree can be shown in the **Github Dependency graph**
for simplicity Github with its onboard equipment was used instead of insisting on complete open source setup - so it is publicly available but not Open Source => Improvement potential
*Hint: You can use a local **ORT-installation** as alternative.*

Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy
- B) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/network/dependencies

*Hint: You can vary the simulation by using a different **available dummy-repository**.*

Supply Chain SBOM Reference Tooling

Dummy Repositories

dummy
repositories

Object under Analysis
OpenChain Tooling Group
Dummy Repositories



Contact:

- Nikola Babadzhanov, Marcel Kurzmann

Landing page:

- https://github.com/Open-Source-Compliance/Sharing-creates-value/blob/master/Tooling-Landscape/Dummy_Repositories/README.md

Benefits:

- Base for benchmarking
- Base for showcasing and testing
- Public collaboration on interesting test-/showcases
- Core maintained by upstream

Details:

- Repos need to be a little bit more complex than „Hello World“ and contain dependencies
- <https://www.youtube.com/watch?v=zJEg2qitPtE>

Public Dummy Repositories - Benefits



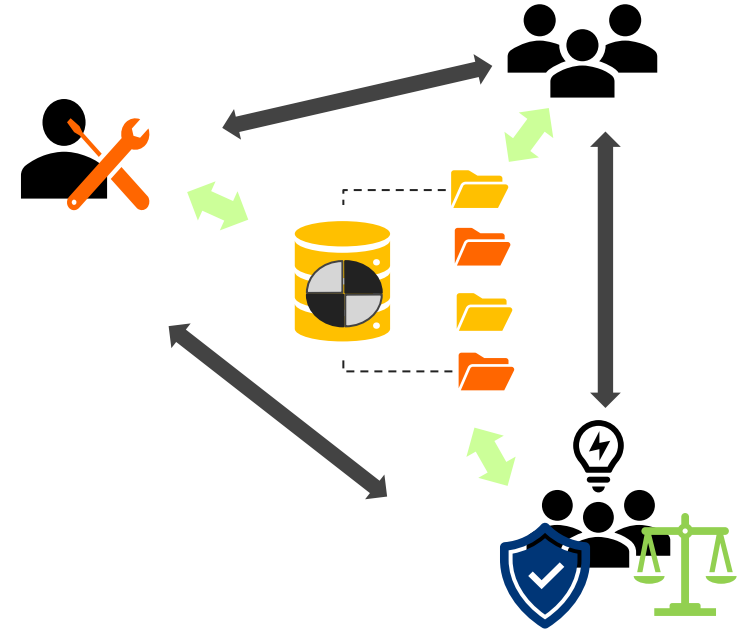
- Benefits for tool vendors and service providers
 - Use as base for testing (and „debugging“)
 - Use for benchmark
 - Reproduce irregular behavior



- Benefits for Users
 - Use for Installation check for SCA tools
 - Reproduce irregular behavior of the used tooling
 - Provide real showcases for benchmark (non-fair weather)



- Benefits for expert community
 - Use as publicly available reference and benchmark for available tools
 - Use as base for trainings/education
 - Reproduce interesting cases by injecting real dependencies with known issues (beyond mere theory)



=> e.g. for automated policies (in the rule engines)

Update on setup

- First repository forked for [Go](#)
- Second repository forked for [Java MAVEN](#)
- Third repository forked for [Javascript NPM](#)



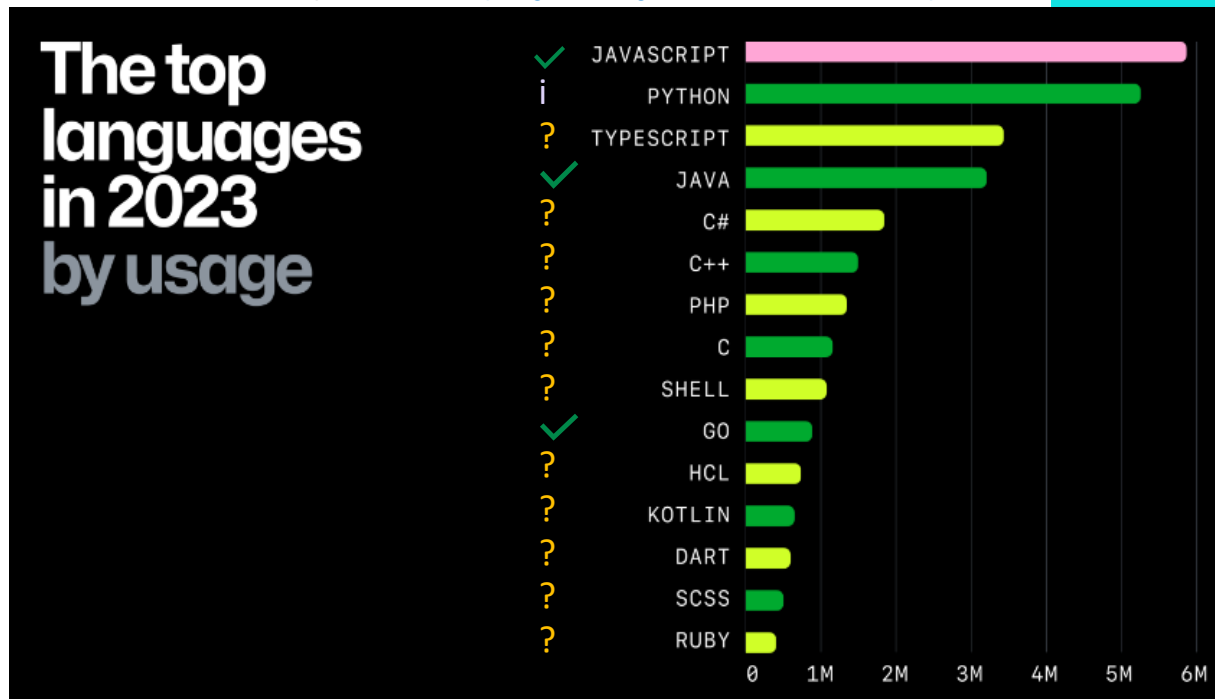
Kudos to the Jenkins Documentation team for providing the base!

Outlook:

- Further prospect identified in
 - <https://github.com/jenkins-docs/simple-python-pyinstaller-app>

Precondition: Maintained by upstream project!

From Octoverse report; Source: <https://github.blog/2023-11-08-the-state-of-open-source-and-ai/>





AI generated image

We need YOU!!!

Please help us finding upstream project that we could use as base for dummies to cover the whole landscape!

Call to action - Help wanted for dummy

help wanted

- **Contribute your cases as „showcases“ / „testcases“** in the dummy repositories (e.g. as a branch – how to described in the link: https://github.com/Open-Source-Compliance/Sharing-creates-value/blob/master/Tooling-Landscape/Dummy_Repositories/README.md)
- Current default show-case: „Log4j 2.14“ (JAVA Maven) or other vulnerable components depending on the context for CyberSecurity
- See issues for ideas in the queue: <https://github.com/Open-Source-Compliance/Sharing-creates-value/issues?q=is%3Aissue%20state%3Aopen%20label%3A%22help%20wanted%22>



The main actors

The software integrator

2.



- OCTTET ORT Test-Server <https://ort-server.occtet.eu/> can be used
 - UI / Login is already functional, first scans were running
 - Communication with Sebastien via Matrix: <https://matrix.to/#/#apoapsis:matrix.eclipse.org>

Part 2 - Software integrator

- A) The simulation uses a "demo" branch in the Dummy Repository to **simulate a modification**
- B) The simulation uses an instance of the **ORT-Server** as **ORT**-based SCA tooling to analyze the repository and generate the SBOM from the Dummy Repository
*Hint: You can use a local **ORT-installation** as alternative.*
- C) The **ORT-report** provides already transparency about all dependencies and findings
- D) The **ORT-reporter** generates the SBOM in CycloneDX and SPDX for further processing

Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/tree/demo/case_001_vulnerability => adds a vulnerable dependency
- B) WIP => will use a Sandbox Org in the public **OCTETT** Test-Server
- C) WIP => the report will be publicly available in the public **OCTETT** Test-Server

Supply Chain SBOM Reference Tooling

Software Composition Analysis

OCTETT ORT
Test -Server

*Software Composition
Analysis*

Eclipse Apoapsis /
OSS Review Toolkit
ORT-Server / ORT

Contact:

- Sebastien Heurtematte
<https://matrix.to/#/#apoapsis:matrix.eclipse.org>

Landing page / „Managed Service“:

- <https://eclipse-apoapsis.github.io/ort-server/>
- <https://ort-server.occtet.eu/>



Benefits:

- Wrapper / Orchestrator
- Standardized automated processing
- Configuration as code
- SBOM generation
- Server with API and management UI

Details:

- <https://openchainproject.org/news/2025/07/02/webinar-project-occtet>

OSS Review Toolkit as virtual conveyor belt



determine the dependencies of projects and their metadata

fetch all source code of the projects and their dependencies

use configured source code scanners to detect license / copyright findings

retrieve security advisories for used dependencies from configured vulnerability data services

evaluate license / copyright findings against customizable policy rules and license classifications

present results in various formats such as visual reports

abstracting which package managers or build systems are actually being used

abstracting which Version Control System (VCS) or other means are used to retrieve the source code.

abstracting the type of scanner.

abstracting the data source for vulnerability data

abstracting the rule set defining the policy rules and license classifications

abstracting the customized representation

Selection of available Open Source Examples:



More details see <https://github.com/oss-review-toolkit/ort/>



The main actors

The manufacturer

3.



- Dependency Track does not provide a public test server (yet), but Docker setup may be used
- For Eclipse Disuko – [Contact info](#)

Part 3 - Manufacturer

- A) the simulation uses the SBOM provided in 2 D) as input to simulate a delivery from a supplier
Hint: The delivery of Software/Binaries is actively ignored for simplification.
- B) the simulation uses a local **OWASP DependencyTrack**-installation as Vulnerability Monitoring Dashboard for incoming supplier SBOMs. A project is created and the CycloneDX SBOM is uploaded. The analysis provides transparency about all dependencies and findings.
- C) Potential extensions:
 - the simulation uses an instance of **Eclipse sw360** for tracking all Software Components
 - the simulation uses an instance of **Eclipse disuko** as SBOM portal

Concrete example used for:

- A) see 2 D)
- B) WIP => the SBOMs will be publicly available in a public sw360 test-server

Vulnerability Monitoring

Dependency
Track Docker

*Vulnerability
Monitoring*

OWASP

Dependency Track



Benefits:

- Dashboard for Projects/Products
- Dashboard for Vulnerabilities
- Continuous Monitoring of static SBOMs
- Vulnerability Audit UI

Details:

- <https://www.youtube.com/watch?v=VpNnxpIBBk0>

Contact:

- Dependency Track Team

Landing page/Managed service:

- <https://dependencytrack.org/>
- Outlook: <https://sbom.eclipse.org/>

Supply Chain SBOM Reference Tooling

SBOM Validation

The logo for Sepia, consisting of a dark blue square with the word "Sepia" in white text.

Sepia

SBOM Validation

OpenChain SBOM
Workgroup
SEPIA



Contact:

- Rakesh Prabhakaran, Nikola Babadzhanov

Landing page :

- <https://github.com/OpenChain-Project/SBOM-sg-SEPIA>

Benefits:

- Validation of SBOM against defined scheme
- Editing SBOMs
- Merging of SBOMs
- SPDX/CycloneDX/SPDX conversion

Details:

- <https://www.youtube.com/watch?v=3CF6adYWQtE>

Supply Chain SBOM Reference Tooling

Detailed Simulation Demo

- See meeting recording from december 3rd 2025
- <https://conf.fsfe.org/presentation/7510c962420cd700b3f46fdc312b8bfe8ec9a608-1764745079345/meeting.mp4>



Summary



- Turnkey reference toolchain that can be used without fees by anybody
- You can try all of this at home
- Open Source Community around tooling is there for helping you in getting engaged
- Please reach out to us in case you even need more support for company internal instance
 - We can match you with people that can provide commercial services around the Open Source solutions
- OpenChain Tooling Work Group meetings every 1st (EU/Asia) and 3rd (US/EU) Wednesday
- <https://groups.io/g/oss-based-compliance-tooling>

**Contributions on all
levels welcome!**



Nikola Babadzhanov

- ***email:*** nikola.babadzhanov@bosch.com
- ***LinkedIn:*** <https://www.linkedin.com/in/nikola-babadzhanov/>

Scan me for contact info

